

Eksamen Cyberforsvar – CYB 2100

HØSTEN 2022

Oppgave 1a

I overgangen til en mer digitalisert og sikker plattform må CISO og teamet identifisere de eksisterende strukturene og prosessene som er gjennomført i det nåværende systemet. Dermed evaluere systemets status og sikkerhets- og risikostyring for å kunne styre arbeidet med sikringen av IKT-systemene. Teamet trenger å få en fullstendig forståelse av virksomhetens behov, systemer og prioriteringer før et sikkerhetsarbeid kan starte. Teamet skal kartlegge virksomhetens leveranser, informasjonssystemer og andre understøttende funksjoner og sammenligne dette opp mot fastsatte toleransegrenser for å bedre kunne utarbeide og forbedre eventuelle eksisterende sikkerhetstiltak (**NSM 1.1**). Teamet trenger en fullstendig liste av virksomhetens enheter og programvarer på nettverket. Disse enhetene, forvaltede og ikke forvaltede, og deres konfigurasjon skal dokumenteres og kun autoriseres etter oppfylt krav (**NSM 1.2**). Teamet skal kartlegge virksomhetens brukere, brukergrupper og deres tilgangsbehov, samt en kartlegging av hvem som har ansvar for IKT-sikkerheten (**NSM 1.3**).

Teamet skal iverksette, ivareta og oppdatere konfigureringer og tilpasninger av maskin- og programvare slik at virksomhetens behov for sikkerhet er tilfredsstillende. Rutiner og sporing, samt rapportering og korrigerende av sikkerhetskonnfigurasjon på programvare, tjenester og enheter vil enten forbedres eller fornyes for å hindre angripere i å utnytte disse (**NSM 2.3**). Det skal etableres regler og rutiner for å ha kontroll på identiteter og tilganger. Virksomheten skal til enhver tid ha oversikt over alle identiteter og kontoer i informasjonssystemene, og skal være i stand til å styre all tilgang til ressurser på en effektiv måte som står i henhold til retningslinjene (**NSM 2.6**). All data som ligger på forskjellige lagringsmedium og når den formidles over informasjonskanaler skal beskyttes. All informasjon skal behandles som sensitiv informasjon, og skal kun leses av brukere med godkjente rettigheter (**NSM 2.7**).

Teamet skal etablere en operativ sikkerhetsovervåkning over alle IKT-systemer i virksomheten og samle inn all relevant data for å best mulig oppdage mulige sikkerhetshendelser og etablere et grunnlag for analyse av data (**NSM 3.2**). Teamet vil kontinuerlig analysere sikkerhetsovervåkningens data i sanntid for å kunne oppdage og

nøytralisere alle former for skadelig aktivitet som kan påvirke informasjonssystemet, data og tjenestene (**NSM 3.3**). Som et tiltak mot angrep vil det bli gjort regelmessige penetrasjonstester mot elementene i systemet for å kunne oppdage eventuelle svakheter i egne forsvarsmekanismer og redusere negative hendelser (**NSM 3.4**).

Teamet skal opprette en serie med instruksjoner som omhandler hvordan en prosess på uforutsette hendelses håndteres i virksomheten. Disse prosessene forklarer hvordan hendelseshåndteringen blir gjort effektivt, slik at hendelsen hurtig kontrolleres, skaden bli minimert og årsaken bak hendelsen blir fjernet, slik at alle systemer og nettverk eksisterer i en operativ modus (**NSM 4.1**). Det skal utføres rutinemessige vurderinger og klassifisering av hendelser for å kunne optimalisere utførelsen av hendelse i tråd med krav og forventninger. Alle hendelser skal utføres korrekt og hurtig i tråd med designert prioritet, og utvalg av nødvendige ressurser og personell (**NSM 4.2**). Alle hendelser som krever en handlingsrespons skal evalueres, dokumenteres og legges til grunn som et fundament for videre læring, for å forhindre at hendelser av den type skjer igjen. Målet er å lære av hendelsene, forbedre sikkerhetstiltak, hendelsesprosesser og opplæring av personell (**NSM 4.4**).

Begrunnelse for valgte grunnprinsipper

Kategori 1 – Identifisere og Kartlegge

1.1 – Det er viktig å få en fullverdig forståelse på eksisterende strukturer og prosesser.

1.2 – Alle enheter og programvarer kan sitte på svakheter, eller være kilden til et angrep. Alt må bli dokumentert for best kontroll.

1.3 – Dette prinsippet tar for seg Zero Trust prinsippet. Man skal kun ha tilgang til det man trenger eller jobber direkte med.

Kategori 2 – Beskytte og opprettholde

2.3 - Det vil alltid eksistere svakheter, men dersom du har en god konfigurasjon til grunne, vil du være i stand til å eliminere en stor mengde, og avlaste mange trusler.

2.6 – IAM.

2.7 - Dette går for to punkter. For at kunden skal ha sin sensitive informasjon, fra bankinfo til kjøpshistorikk, sikker. Og for at informasjon fra virksomheten sin side er sikker, men også utilgjengelig for andre.

Kategori 3 - Oppdage

3.2 – En god sikkerhetsovervåkning sørger for at virksomheten har nøyaktig, relevant data for å oppdage sikkerhetshendelser og som et grunnlag for analyse av data.

3.3 – Gjennom en analyse av dataen gitt av sikkerhetsovervåkingen vil virksomheten være i stand til å lettere oppdage skadelig aktivitet som kan påvirke systemene.

3.4 – Jeg valgte 3.4 fremfor 3.1 av følgende grunner. Dersom prinsipp 2.3 blir gjort på best mulig måte vil mange av de kjente svakhetene i et system elimineres. Som et følge av en sikkerhetsoppgradering vil det være nødvendig å utføre en inntrengertest fra en ekstern part. Denne parten vil opplyse om alle eventuelle svakheter de finner, og samtidig gjøre virksomheten oppmerksom på alle svakheter punkt 2.3 ikke dekker.

Kategori 4 - Håndtere og Gjenopprette

4.1 – For hvert minutt en tjeneste er nede vil det potensielle økonomiske tapet øke. Jo fortere en feil/skade/tjenestenekt er løst, desto mindre økonomisk tap vil virksomheten risikere.

4.2 – Gjennom klassifisering av sikkerhetshendelser vil virksomheten raskt og korrekt kunne håndtere hendelsen, uten å måtte involvere alle.

4.4 – Det er viktig å kunne å kunne lære av alt. Spesielt feil. Gjennom dette prinsippet vil virksomheten stille seg sterkere ved hver hendelse og øke den helhetlige sikkerheten for både tiltak, prosesser, personell og forbedre prosedyrer.

Oppgave 1b

Tiltak 1 – Informasjonssikkerhet

For å kunne bli utsatt for et ransomware-angrep må trusselaktøren først og fremst få tilgang til virksomhetens data. Dette kan oppnås på flere måter, men det er først og fremst en sterk fellesnevner. 95% av alle cybersikkerhetsbrudd skjer som et følge av en menneskelig feil (Mee, 2020). Dette kan være fra å trykke på en lenke de ikke skulle trykket på, åpne en e-post og vedlegg fra en «kollega», miste en enhet som tilhører virksomheten, bruke en USB-enhet de fant eller fikk, eller kanskje avansert social engineering. Det første tiltaket vil være å styrke virksomhetens ansatte i grunnleggende IKT-sikkerhet. Å lære grunnleggende ferdigheter som å bruke sterke passord, identifisere phishing-svindel og forstå hvordan data samles inn og hvordan en digital identitet spores på nettet, kan dramatisk forbedre sikkerheten og dataen til både de ansatte og virksomheten.

Tiltak 2– Principle of least Privilege.

Man må kunne forvente at det på et punkt vil være et sikkerhetsbrudd. Dette sikkerhetsbruddet vil ha en variert konsekvens avhengig av hvem som ble hacket. Med tilgang til systemet, vil trusselaktøren gjøre sitt beste for å ta til seg all data hen overhodet kan og forsøke å spre kontrollen sin. Ved at virksomheten benytter seg av Principle of least Privilege (POLP) vil trusselaktøren kun ha tilgang til den dataen og rettighetene som offeret satt på. Principle of least Privilege er et kjerneprinsipp for Zero-Trust der brukere gis minimal nødvendig tilgang til applikasjoner eller systemer for å kunne utføre oppgavene sine. Dette resulterer i at den begrensede tilgangen forhindrer at ingen, hverken feilaktig eller intensjonelt, tukler med filer og andre sensitive data utenfor deres ansvarsområde. For å få eleverte rettigheter må brukeren be administratoren om tillatelse, og i en virksomhet med en god sikkerhetskultur vil administrator, som operer med regelen «alle brukere og forespørsler er upålitelige», stille spørsmål direkte til brukeren rundt elevering av rettighetene. Dersom brukeren benekter forespørselen vil det fort komme frem at brukeren har blitt hacket. Ytterligere tiltak vil være å benytte seg av et Privileged Account Management (PAM). Dette sørger for at det alltid vil kun være et minimum av brukere som har tilgang på en ressurs, og kun i en begrenset periode.

Tiltak 3 – Backup, Encryption, Backup.

Dersom en hendelse som involverer ransomware skulle oppstå så er viktig at virksomheten ikke trekker forhastede konklusjoner. Under et ransomware vil trusselaktøren sitte på en viss mengde data som kan være kritisk for virksomhetens operative evne. Virksomheten må være i stand til å utføre sikkerhetskopier av alle systemer og data. Disse sikkerhetskopiene skal i tillegg lagres utenfor virksomhetens nettverk. Det må også utføres tester for å sikre at gjenoppretning skjer korrekt. En sikkerhetskopiering vil derimot ikke være den eneste og sikreste løsningen. Det finnes avansert ransomware som eksfiltrerer dataene og bruker det som en dobbeltutpressingsmetode (*Tudor, 2020*). Informasjon i skyen bør lagres kryptert og sikkerhetskopier bør testes regelmessig for ytelsessjekker. En offline sikkerhetskopi som en harddisk kan være nyttig. En lagringsløsning, Write-Once-Read-Many (WORM), vil lagre informasjonen din i en enhet og låse den slik at den ikke kan endres. Du kan også beskytte sikkerhetskopien med endepunktbeskyttelse på serverne dine.

Oppgave 1c

Tjeneste 1 – Deteksjon

En SOC eksisterer for å kontinuerlig monitorere og forbedre en virksomhets sikkerhet, mens den samtidig forhindrer, oppdager, analyserer og responderer til sikkerhetshendelser. For at en SOC skal kunne utføre sin primære handling må den være i stand til å oppdage trusler og angrep mot en virksomhet. En SOC uten deteksjon er som en narko-hund uten luktesans. En virksomhet som er avhengig av høy operativ status trenger SOC Deteksjon for å kunne oppdage uønskede hendelser. Dette oppnås gjennom analyse av data samlet inn på tvers av organisasjonen, utførelsen av hand-over til hendelseshåndtering, sammenstille og se begivenheter på kryss av loggkilder, og korrelere mot informasjon fra eksterne og interne kilder (Ramberg, 2022). Dette er en kostbar og krevende oppgave, med krav til kvalitet i kilder og fokus på verktøy. Til tross for dette er Deteksjon en av de viktigste tjenestene en SOC kan tilby.

Tjeneste 2 – Hendelseshåndtering

En sikkerhetshendelse kan og vil koste virksomheten tid, penger, rykte og potensielt kunder. Å ha en effektiv hendelseshåndtering vil minimere denne risikoen. Uavhengig om hendelsen skulle være et DDOS angrep, databrudd, malware, eller en trussel fra innsiden, så vil en god hendelseshåndtering innebære en rask koordinering av tilgjengelige ressurser og sikkerhetsteamet som vil håndtere trusselen, for å så effektivt gjenoppta virksomheten til optimal drift. Denne tjenesten er en stor fordel da den vil eksistere in-house.

Tjeneste 3 – Sårbarhetshåndtering

I trinn med teknologiens utvikling vil også trusselaktørene få tilgang til større og sterkere våpen. Antall CVE'er per år øker eksponentielt, og tiden mellom patcher forblir mye den samme. Sårbarhetshåndtering er en kritisk del av en SOC sine tjenester i dens evne til å identifisere og fikse sårbarheter i organisasjonen. Både eksterne og interne angrepsflater. Sårbarhetshåndteringen skiller seg ut av to grunner. For det første er ingen to saker identiske. For det andre så vil all håndtering kreve et samarbeid av mennesker, prosesser og tekniske elementer for å løse oppgaven. Sårbarhetshåndteringen virksomheten vil benytte seg av vil skje in-house, som reduserer responstiden hendelseshåndtering trenger for å utføre oppgaven sin. Det er i tillegg viktig med Sårbarhetshåndtering som en tjeneste, da virksomheten ønsker å utvide til et digitalt marked. Dette vil gi virksomheten ekstra sikkerhet rundt klienter, servere, infrastrukturenheter og mobile enheter.

Tjeneste 4 – Rapportering

Gjennom en digital satsning, vil virksomheten bruke store summer penger. Dette kan være penger som virksomheten ikke har direkte, men får gjennom aksjeholdere og andre eiere. I en nysatsning er det viktig å kunne være transparent og vise sine investorer hvilke resultater satsningen kan vise til. Det er knyttet en risiko til alle prosjekter, og i et digitaliseringsprosjekt gjelder dette ofte sterkere da man kun får ett førsteinntrykk. Investorer er interesserte i gevinst og resultater. Dette vil de få gjennom regelmessige rapporter. Det er derfor viktig å etablere Rapportering som en tjeneste, for å vise en kontinuerlig flow av tillit og resultater til sine investorer

Oppgave 2

2.a – Beskriv elementer i Splunk

Search head	Search head er en primærkomponent brukt for å samhandle med Splunk. Den gir brukere et grafisk grensesnitt for å utføre ulike søkefunksjoner innenfor tilgjengelig data. Man søker og spør etter data som ligger lagret de forskjellige indexene basert på søkeord. For eksempel «categoryid=sports»
Single Index	Singel indeksen indekserer data, transformere rådata til hendelser og plasserer resultatene i en indeks. Dem søker også i de indekserte dataene som svar på søkeforespørsel. Indeksen utfører også ofte de andre grunnleggende Splunk funksjonene som inndata og søkeadministrasjon.
Cluster Index	Cluster Index er en (grupper) av indekser konfigurert til å replisere hverandres data slik at systemet beholder flere kopier av all data. Dette forhindrer tap av data samtidig som de fremmer data-tilgjengelighet for søk. Cluster Index' er i mange tilfeller enklere å administrere enn grupper av Single Index'.
Heavy Forwarder	I motsetning til andre typer Forwarders vil denne typen alltid analysere dataen før den videresender den, og er i stand til å route data basert på kriterier som for eksempel kilde eller type hendelser. Dette utføres i selve kilden gjennom indeksering og parsing, og leder til et redusert bruk av båndbredde og lagringsplass.
Universal Forwarder	Universal Forwarder er en mer dedikert og strømlinjeformet versjon av Splunk som kun inneholder de essensielle komponentene som trengs for å videresende data. Dette er i de fleste tilfeller den beste måte å videresende data til indekser, men det ligger en begrensning i at den videresender uparsede data, bortsett fra i visse tilfeller det du for eksempel finner strukturerte data. I de tilfellene der man finner hendelsesbaserte data må man bruke en Heavy Forwarder

(Splunk, 2022)

2.b – Kjør spørring og forklar

Etter å ha kjørt spørringen får vi opp filstien «C:\inetpub\wwwroot\joomla\3791.exe». Vi kan ut ifra dette konkludere at det er snakk om Windows som operativsystem for to grunner. Filstien starter med 'C:\'. I Linux og Mac OS vil alle filstier starte med '/', som symboliserer 'root'. Vi finner også i filstien at filen er en '.exe' fil. Det er kun Windows som bruker '.exe', forkortet fra 'executable'.

Joomla er en Content Management System (CMS og opererer med to kjente webservere. Apache og Microsoft IIS (Internet Information Service). Siden Joomla i utgangspunktet er designet for å kjøre på en Linux-basert webserver og vi allerede har konkludert at dette er Windows, kan det være logisk å se bort ifra Apache. Dette betyr ikke at man ikke kan installere Apache på Windows, men Apache på Windows har 'C:\Program Files\Apache...' som default filsted, og det virker ulogisk å installere Apache på samme sted som Microsoft IIS, da de også deler samme port. Vi ser også i filstien at vi finner Joomla i mappene '\inetpub\' og '\wwwroot\''. Da filstien peker til disse to mappene, gir det oss større grunn å ekskludere Apache som Webserver. Dette etterlater oss med Microsoft IIS. Igjen, siden Joomla er designet for å kjøre på en Linux-basert webserver, så vil en installasjon av Joomla på Microsoft IIS være mindre stabil, og i en større grad utsatt for feil og sårbarheter. Dette er trolig en av grunnene til at angriperen fikk lastet opp den ondsinnede filen til serveren. Etter en vurdering vil jeg konkludere at det er Microsoft IIS som er webserveren.

Den første og enkleste måten å forhindre opplasting av ondsinnede filer på er gjennom Extensions-regler. Hvitelist hvilke typer filer en bruker kan laste opp til nettsiden, og verifiser fil typen. På den måten kan vi unngå at en angriper maskerer en filtype ved å endre navnet fra for eksempel .exe til .docx fil. Den andre metoden er gjennom et antivirus-program. Dersom du har en webserver hvor en kan laste opp filer er det viktig å implementere grunnleggende brannmur-innstillinger og et, eller flere, anti-virus program som er i stand til å skanne og karantene filer.

2.c – Hvorfor Sentinel fremfor Splunk

Sentinel er en av de beste *alternativene* til Splunk, absolutt. Men, for å kunne legge frem hovedfordelene til hvorfor en skal velge Sentinel fremfor Splunk er det viktig å først utdype hvem Splunk er for og dens styrker. Splunk er en «data-to-everything» sikkerhetsplattform som tilbyr alt fra sikkerhetsanalyse, SIEM, automatisering, sårbar- og hendelseshåndtering

osv. Splunk er et relativt lite selskap, og som et følge rapporteres det at brukere opplever et mer personlig og direkte forhold til løsningen og Splunk. Den har alt på ett sted, men det kan dessverre ta litt tid å lære seg Splunk som en helhet grunnet "reliance on query language" (R2UT, 2020). Splunk gir et helhetlig godt dekket sikkerhetsprodukt, men er i utgangspunktet gunstigere for små og mellomstore bedrifter. La oss nå ta for oss grunner til å velge Microsoft Sentinel som et av de beste alternativene. Microsoft er et større selskap med en lang historie. Selv om Sentinel kom var ute på markedet først i 2019, sammenlignet med Splunk som har vært ute siden 2003, så har Microsoft et større budsjett, nyere og sterkere teknologi, og en høyere tillit blant brukere. Sentinel tilbyr en tjeneste som er lettere å distribuere, lettere å vedlikeholde og det innlemmer seg lett med andre infrastrukturer uten store mengder konfigurasjon. Microsoft Sentinel's «near-real-time» (NRT) kjører automatisk hvert eneste minutt og fanger all trafikk har skjedd, og en AI analyserer dataen for regelmessig oversikt. I tillegg til å være et SIEM-system, er også Sentinel en Security, orchestration, automation and response (SOAR) platform. Som et relativt nytt produkt har Sentinel ha glede av en veldig moderne, men forståelig GUI som gjør det lett for nye brukere å lære seg hvordan løsningen fungerer. Dette, i kombinasjon med at Sentinel opererer med en pay-for-use modell, så vil du enkelt forstå løsningen uten å ha risikert store utgifter grunnet uforsiktighet. Som en oppsummering kan man si at Sentinel har større muskler i form av teknologi og funksjoner, har en større fleksibilitet og «fin-tuning», og er i grunn langt mer brukervennlig.

Oppgave 3

3.a – Utgangspunkt i sjekksum

Sjekksummen viser til ransomware-viruset NotPetya. NotPetya (2017) var en ny og litt mer avansert versjon av Ransomware-viruset Petya, som kom året før. NotPetya spredde seg via EternalBlue, en sårbarhet først utnyttet av NSA, som benyttet seg av en svakhet i Windows' Server Message Block (SMB) protokoll. Denne samme svakheten er også brukt i WannaCry. NotPetya samlet inn passord ved å bruke en modifisert versjon av Mimikatz, og andre teknikker for å spre seg til andre datamaskiner på det samme nettverket, og bruker da de passordene i konjunksjon med PSEXEC (verktøy som tillater fjernstyring ved bruk av en brukers brukernavn/passord) til å kjøre kode på andre datamaskiner på nettverket. Det som gjorde viruset litt interessant var at krypteringen var permanent i den forstand at skadevaren ikke kunne reversere skadene sine. Det diskuteres også hvorvidt denne

skadevaren var skapt som et forsøk på profitt eller om det var et forsøk på å effektivt skade enheter og ri på bølgen til WannaCry, da betalingssummen (i bitcoin, selvfølgelig) kun tilsvarte 300\$ (BBC, 2020). I lys av spenningen mellom Ukraina og Russland er det konkludert at Ukraina var hovedmålet bak NotPetya. Skyld til skaperne/angrepene bak NotPetya har havnet på den Russiske regjeringen. Mer spesifikt, Sandworm, som var en hackergruppe i GRU Russisk militære (Greenberg, 2018).

3.b – Volatility

For å finne passordet til Administrator måtte jeg først ta for meg bildefilen og forstå den infoen og profilen som Volatility ga meg.

```
(kali@kali)-[~/Desktop/Volatility]
$ ./volatility -f ~/Desktop/IE10WIN7-20221114-202804.raw imageinfo
Volatility Foundation Volatility Framework 2.6
INFO : volatility.debug : Determining profile based on KDBG search...
and for Suggested Profile(s) : Win7SP1x86_23418, Win7SP0x86, Win7SP1x86
of our new features AS Layer1 : IA32PagedMemoryPae (Kernel AS)
AS Layer2 : FileAddressSpace (/home/kali/Desktop/IE10WIN7-20221114-202804.raw)
PAE type : PAE
```

Jeg hentet deretter en oversikt over alle registry hives gjennom en hivelist-plugin:

```
0x91804950 0x1fbaa950 \Device\HarddiskVolume1\Boot\BCD
0x9180e008 0x20d70008 \SystemRoot\System32\Config\SOFTWARE
0x91820688 0x1bcf6688 \??\C:\Windows\System32\config\COMPONENTS
0xa0085330 0x1efee330 \??\C:\System Volume Information\Syscache.hve
0xa0194540 0x13895540 \??\C:\Users\sshd_server\ntuser.dat
0x8201a008 0x1301a008 \??\C:\Users\sshd_server\AppData\Local\Microsoft\Windows\UsrClass.dat
0x87c0e308 0x280dd308 [no name]
0x87c1a008 0x2806b008 \REGISTRY\MACHINE\SYSTEM
0x87c439c8 0x27fd69c8 \REGISTRY\MACHINE\HARDWARE
0x87cb79c8 0x1ab7e9c8 \SystemRoot\System32\Config\SECURITY
0x87cc99c8 0x164c29c8 \SystemRoot\System32\Config\DEFAULT
0x87ccb008 0x1a60c008 \SystemRoot\System32\Config\SAM
0x881ca9c8 0x14b699c8 \??\C:\Windows\ServiceProfiles\NetworkService\NTUSER.DAT
0x88d32008 0x065e5008 \??\C:\Users\IEUser\ntuser.dat
0x88d36008 0x01d4d008 \??\C:\Users\IEUser\AppData\Local\Microsoft\Windows\UsrClass.dat
0x8985a008 0x18e9d008 \??\C:\Windows\ServiceProfiles\LocalService\NTUSER.DAT
```

Etter litt leting fant jeg et registry som hadde det jeg så etter.

```
(kali@kali)-[~/Desktop/Volatility]
$ ./volatility -f ~/Desktop/IE10WIN7-20221114-202804.raw --profile=Win7SP1x86_23418 hashdump -y 0x87c439c8
Volatility Foundation Volatility Framework 2.6
Administrator:500:aad3b435b51404eeaad3b435b51404ee:96d3e89d052ee81604174875eb9de565:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
IEUser:1000:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
sshd:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
sshd_server:1002:aad3b435b51404eeaad3b435b51404ee:8d0a16cfc061c3359db455d00ec27035:::
```

Ved å kjøre '96d3e89d052ee81604174875eb9de565' gjennom crackstation.net fant jeg ut at passordet er 'Liverpool'.

Oppgave 3.c – Yara og mimikatz.exe

```
(kali@kali)-[~/Desktop]
$ yara -r ../Documents/yarafolder/examyara.yar ./
exam_yara ../mimikatz32.exe
exam_yara ../mimikatz64.exe
```

Kjører Yara regelen min og får ut mine to mimikatzfiler. Filene ligger i en mappestruktur som gjør at dersom jeg kun setter mimikatz som \$a string vil den trigge flere filer enn kun de to exe filene.

```
rule exam_yara {  
  meta:  
    Description = "This rule exists to find the two mimikatz files"  
    Author = "Student"  
    hash = ""  
  strings:  
    $a = "http://blog.gentilkiwi.com/mimikatz"  
  condition:  
    $a and  
    (filesize > 870KB) and (filesize < 1375KB)  
}
```

Jeg tok også høyde for at filene kan øke med inntill 10% gjennom litt rask matte.

3.d – 3 Tiltak mot Lateral Movement

Tiltak 1 – Least privilege access

Jeg vil alltid mene at PoLP vil være en av de sikreste forsvarsmekanismene dersom en inntrenger har fått tilgang til virksomhetens nettverk. Lateral movement er en veldig normal angrepsstrategi, hvor dersom inntrengerer ikke klarer å nå hovedmålet, for eksempel en databaseserver, så vil hen forsøke å spre kontrollen sin innenfor samme nettverk til hen er i stand til å nå målet. Gjennom Principle of Least Privilege vil angrepsflaten bli sterkt redusert, angrepsprogresjonen blir sakkett ned og angriperen risikerer større sjanse for å bli tatt.

Tiltak 2 – Overblikk på endepunktssikkerheten

Ettersom moderniseringen av arbeidsplassen med distribuerte team og eksternt arbeid normaliserer seg, vil det i mye større grad bli et fokus for virksomhetene å sikre hvert enkelt endepunkt som kobles til virksomhetens nettverk, uavhengig av dets fysiske plassering. Viktigheten av synlighet gjelder like mye for bærbare datamaskiner og mobile enheter som kobles eksternt som for stasjonære datamaskiner på kontoret og enheter koblet direkte til nettverket. Økt synlighet i hvert endepunkt vil føre til et mer detaljert bilde av hva som utgjør normal aktivitet og brukeratferd. Jo mer detaljert din interne nettverksintelligens er, desto lettere er det å identifisere trusler og beskytte enheter eksternt.

Tiltak 3 – Gjennomfør mikrosegmentering

Mikrosegmentering er argumentativt den sterkeste måten å forhindre og oppdage lateral movement i virksomhetens nettverk. WannaCry og NotPetya, to kjente ormer, brukte lateral movement for å transformere det som kunne ha vært kontrollerbare brudd til fullskalaangrep. Mikrosegmentering deler nettverk inn i nøyaktig definerte soner som kan beskyttes uavhengig for å styrke det overordnede nettverkets sikkerhetsposisjon. Sikring av hvert endepunkt som et mikrosegment reduserer den tilgjengelige angrepsoverflaten, reduserer risikoen, og samtidig øker sikkerhetsteamenes evne til å forhindre, oppdage og svare på angrep på enheter hvor som helst i verden.

Referanseliste:

- Mee, P. (2020, December 17) *After reading, writing and arithmetic, the 4th 'r' of literacy is cyber-risk*. Weforum. <https://www.weforum.org/agenda/2020/12/cyber-risk-cyber-security-education>

- Tudor, D. (2022, June 22) *How to prevent ransomware*. Heimdalsecurity <https://heimdalsecurity.com/blog/how-to-prevent-ransomware/>

- Ramberg, H. (2022, September 14) *Soc Services - Lesson 3.2, Side 7. Deteksjon*. Høyskolen Kristiania. https://kristiania.instructure.com/courses/9527/files/938454?module_item_id=337123

- Splunk (2022) *Splexicon: the Splunk glossary*. <https://docs.splunk.com/Splexicon>

- R2 Unified Technologies (2020) *Comparing Microsoft Sentinel vs. Splunk* <https://blog.r2ut.com/comparing-microsoft-sentinel-vs.-splunk>

- BBC (2017, June 29) *Cyber-attack was about data and not money, say experts*. <https://www.bbc.com/news/technology-40442578>

- Greenberg, A. (2018, August 22) *The Untold Story of NotPetya, the Most Devastating Cyberattack in History*. Wired <https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>